

КЫРГЫЗСКИЙ ГОСУДАРСТВЕННЫЙ ТЕХНИЧЕСКИЙ
УНИВЕРСИТЕТ ИМ И. РАЗЗАКОВА

ИНСТИТУТ ИНФОРМАЦИОННЫХ ТЕХНОЛОГИЙ
КАФЕДРА “ПРОГРАММНОЕ ОБЕСПЕЧЕНИЕ
КОМПЬЮТЕРНЫХ
СИСТЕМ”

Отчет

По дисциплине “Secure Software Development and Maintenance 2”
На тему : “ Мобильное приложение Тулпар ”

Работу выполнили студенты :
Группы ПИ(англ)-2-
22 Каныбекова
А. Б.

Преподаватель :
Ашымова А.Ж.

Бишкек 2025 г.

Оглавление

Техническое задание.....	3
1. Обзор.....	3
1.1. Введение.....	3
Наименование проекта.....	3
Основание для разработки.....	3
1.2. Цель и назначение программы.....	3
Цель проекта.....	3
Система предназначения для.....	3
1.3. Описание системы.....	4
Мобильное приложение “Тулпар” представляет собой систему для.....	4
В системе реализовано клиент-серверное взаимодействие.....	4
1.4. Технические требования.....	4
1.5. Требования к безопасности.....	4
Система должна.....	4
2. Активы, описание системы с точки зрения безопасности.....	5
Основные активы системы.....	5
CVE-2025-62228	
Мб несколько.....	5
3. Модель нарушителя.....	6
Цель нарушителя.....	6
Типы нарушителей.....	6
Возможность нарушителя.....	7
4. Актуальные угрозы и модель угроз.....	7
Возможность нарушителя.....	7
5. Проект политики.....	8

Техническое задание

1. Обзор

1.1. Введение

Наименование проекта

Система безопасности мобильного приложения “Тулпар” – транспортной карты Кыргызстана

Основание для разработки

Работа выполняется в рамках учебной дисциплины *Secure Software Development and Maintenance 2* с целью анализа угроз, активов и разработки модели нарушителя для мобильного приложения электронных платежей в общественном транспорте.



1.2. Цель и назначение программы

Цель проекта

Целью разработки является обеспечение **комплексной информационной безопасности мобильного приложения “Тулпар”**, предназначенного для управления электронными транспортными картами различных категорий граждан.

Основная цель системы — предотвращение несанкционированного доступа, утечек персональных данных и мошеннических операций, а также обеспечение достоверности и защищённости транзакций при использовании карт всех типов — общей, школьной и льготной.

Система предназначена для :

- безопасного хранения и обработки персональных данных пользователей, включая категории льготных кар (ФИО, телефон, идентификатор карты итд.)
- автоматической проверки категории карты и применения соответствующих тарифов
 - Стандартный тариф
 - Проезд - 17 сом
 - Месячный проезд - 1020 сом/месяц
 - Льготный тариф (красная карта)
 - 100% бесплатный
 - Школьный тариф (зеленая карта)
 - Проезд - 17 сом

- Месячный проезд - 360 сом
- защиты каналов связи между мобильным приложением и сервером
- предотвращения атак типа SQL-инъекция, XSS, MITM, повторных транзакций и подделки токенов
- предоставления пользователю безопасного доступа к информации о балансе и истории поездок
- реализации механизмов аутентификации, авторизации и контроля целостности данных

1.3. Описание системы

Мобильное приложение “Тулпар” представляет собой систему для :

- Пополнения транспортной карты
 - Через терминал;
 - Через онлайн-банк.
- Просмотр баланса и истории поездок;
- Оплаты проезда с помощью QR-кода или NFC;
- Покупки проездных абонементов;
- Интеграции с учетной записью пользователя и банковскими сервисами :
 - Личный кабинет пользователя
 - Пополнение карты и оплата проездного абонемента.

В системе реализовано клиент-серверное взаимодействие:

- **Клиентская часть (мобильное приложение)** — реализована на Android / iOS, содержит интерфейс пользователя и модули авторизации.
- **Серверная часть (backend)** — обеспечивает хранение данных, проверку подлинности карт, выполнение транзакций и взаимодействие с банками.
- **База данных** — содержит персональные данные, идентификаторы карт, журнал операций и финансовую информацию.

1.4. Технические требования

1.5. Требования к безопасности

Система должна :

- Реализовать безопасное хранение паролей;
- Использовать защищённый протокол HTTPS / TLS для передачи данных;

- Обеспечивать защиту от SQL-инъекций, XSS, MITM и повторных транзакций;
- Иметь систему уведомлений о подозрительных операциях;
- Поддерживать двухфакторную аутентификацию.
- реализовать контроль доступа и разграничение прав между пользователями и администраторами;
- обеспечивать дополнительную проверку для школьных и льготных карт (ветераны, пенсионеры, инвалиды);
- защищать мобильное приложение от модификаций и подделки.

2. Активы, описание системы с точки зрения безопасности

Основные активы системы :

- Персональные данные пользователей
- Баланс транспортной карты
- Данные транзакций
- Сервер приложения
- Данные о мобильном устройстве пользователя
- Банковские шлюзы

Добавить CVE писание до таблицы

CVE-2025-62228

Apache Flink CDC version 3.4.0 was vulnerable to a SQL injection via maliciously crafted identifiers eg. crafted database name or crafted table name. Even through only the logged-in database user can trigger the attack, we recommend users update Flink CDC version to 3.5.0 which address this issue.

Табл. 1 Идентификация актива

№	Процесс	Актив	Описание / среда обработки	Приоритет	Уязвимость
1	Основные бизнес процессы (регистрации, авторизации)	Персональные данные пользователей	ФИО, номер телефона, ID карты, платежные реквизиты, тип карты	Вы... ▾	CVE-2025-62228 Мб несколько
2	(пополнение баланса)	Баланс транспортной карты	Финансовая информация, подвержена	Вы... ▾	

			мошенничеству		
3		Данные транзакции	История поездок и пополнений	Сре... ▾	
4		Сервер приложения	Основное хранилище данных и API	Кри... ▾	
5		Мобильное устройство пользователя	Потенциальная точка атаки	Сре... ▾	
6		Банковские шлюзы	Финансовые операции (посредник между банком и покупателем)	Кри... ▾	

3. Модель нарушителя

Цель нарушителя :

Получить несанкционированный доступ к данным пользователей, изменить баланс транспортной карты или подделать транзакцию.

Типы нарушителей :

- **Внешний злоумышленник :**
 - Не имеет прямого доступа к внутренним ресурсам системы.
 - Использует вредоносные программы, фишинг, перехват трафика (MITM), взлом приложения или подделку карт.
 - **Цель** — получение персональных данных, кража денег или несанкционированное использование транспортных карт.
- **Внутренний злоумышленник :**
 - Сотрудник компании, имеющий частичный или полный доступ к базе данных или административной панели.
 - Может злоупотреблять своими правами, изменять информацию, копировать данные пользователей или способствовать утечке данных.
 - **Цель** : причинить вред активам компании, продажа персональных данных
- **Технический нарушитель (хактивист) :**
 - Обладает техническими знаниями в области ИБ и может использовать уязвимости кода, API или криптографических механизмов.

- **Цель** — исследование, взлом или демонстрация уязвимости, иногда без прямой финансовой мотивации.

- **Техногенные угрозы**
 - связаны с неисправностью оборудования, программным сбоем или инфраструктурными проблемами.
- **Другие менее важные типы**
 - Технический нарушитель (хактивист)

Обладает техническими знаниями в области ИБ и может использовать уязвимости кода, API или криптографических механизмов.

Цель — исследование, взлом или демонстрация уязвимости, иногда без прямой финансовой мотивации.
 - Случайный нарушитель (ошибка пользователя или сотрудника)

не имеет злого умысла, но нарушает политику безопасности из-за неосторожности.
- **Транспортные карты не несут в себе особой ценности для злоумышленников с финансовыми намерениями, так как в тупаре отсутствует возможность выводить баланс с карты, только оплата транспорта**

Возможность нарушителя :

- Анализ трафика между клиентом и сервером;
- Использование поддельных приложений или инструментов reverse engineering (**взломка мобильного приложения**);
- Подбор паролей и кража токенов сессии;
- Внедрение вредоносного кода в мобильное приложение.
- Фишинг и социальная инженерия с вредоносными рассылками
- Для внутреннего злоумышленника :
 - Саботаж, **слив в интернет** персональных данных пользователей к которым у них есть доступ.
 - Инициация некорректных транзакций или отмена операций, чтение и изменение записей
 - Чтение/изменение записей в базе данных (персональные данные, балансы)
 - Продажа

4. Актуальные угрозы и модель угроз

Возможность нарушителя :

- перехват сетевого трафика и кража данных пользователей;
- подделка или клонирование транспортных карт;

- атаки на сервер (SQL-инъекции, ДДОС);
- использование фальшивых льготных карт или с истекшим сроком годности или посторонними;
- Фишинг-рассылки
- утечка данных через внутреннего нарушителя.
- **взлом мобильного устройства? саботаж**

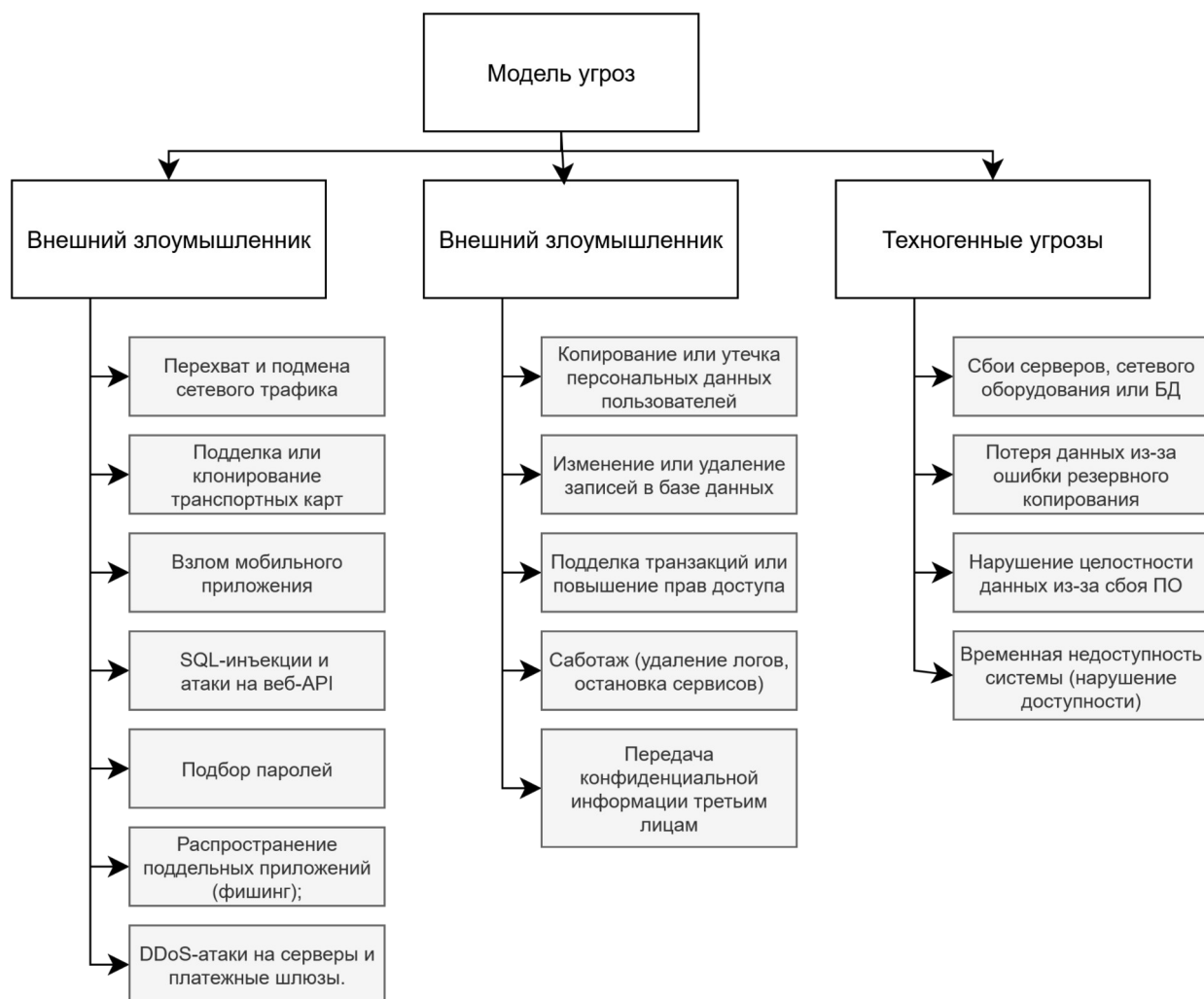


Рис. 2 Модель угроз

5. Проект политики

Политика безопасности системы «Тулпар» основывается на принципах конфиденциальности, целостности и доступности данных.